Système de Contrôle d'Accès

Banque Internationale

Auteurs
Achraf Hasnaoui & Mohamed Aziz Foudhaili

Module
Sécurité des systèmes d'information

Modèles couverts
RBAC · ABAC · BLP · Biba · Chinese Wall

Date
Mai 2026

Document pédagogique — usage interne

0. Table des matières

1 Introduction

2 Acteurs et opérations

- 2.1 Acteurs du système
- 2.2 Opérations métier principales

3 Modèles de contrôle d'accès

- 3.1 RBAC — Role-Based Access Control
- 3.2 ABAC — Attribute-Based Access Control
- 3.3 BLP — Bell-LaPadula (confidentialité)
- 3.4 Biba — Modèle d'intégrité
- 3.5 Chinese Wall — Brewer-Nash (conflits d'intérêt)

4 Architecture en couches

5 Niveaux de sécurité

6 Division en équipes et effectifs

- 6.1 Guichetier — 50 agents (10%)
- 6.2 Relation clientèle — 120 agents (24%)
- 6.3 Back-office — 80 agents (16%)
- 6.4 Gestion de patrimoine — 60 conseillers (12%)
- 6.5 Risque — 40 analystes (8%)
- 6.6 Conformité / AML — 35 agents (7%)
- 6.7 Audit interne — 20 auditeurs (4%)
- 6.8 Juridique — 20 juristes (4%)
- 6.9 Cadres commerciaux — 25 cadres (5%)
- 6.10 Experts régionaux temporaires — pool de 10
- 6.11 Récapitulatif des effectifs

7 Requêtes de test du système d'accès

8 Règles transverses

9 Conclusion

1. Introduction

Une banque internationale doit concilier deux exigences opposées : laisser chaque équipe travailler efficacement, et empêcher tout accès non autorisé aux données sensibles. Le présent document décrit l'architecture complète du système de contrôle d'accès, couvrant l'ensemble des acteurs — y compris le **guichetier** en première ligne — et présente un ensemble de requêtes de test permettant de valider le bon fonctionnement du dispositif en conditions réelles.

Pour répondre à ces exigences, le système repose sur une architecture en couches combinant cinq modèles complémentaires :

- **RBAC** — gestion des rôles et héritages de permissions
- **ABAC** — filtrage contextuel (portefeuille, pays, durée)
- **BLP** — protection de la confidentialité (niveau critique)
- **Biba** — protection de l'intégrité des données
- **Chinese Wall** — prévention des conflits d'intérêt

Chaque modèle couvre une dimension différente. Ensemble, ils forment un dispositif complet et conforme aux exigences GAFI, ACPR et Bâle III/IV.

2. Acteurs et opérations

2.1 Acteurs du système

Acteur	Rôle	Niveau d'accès
Guichetier	Accueil physique, opérations courantes au comptoir	N1
Employé back-office	Traitement des opérations et corrections admin.	N1 – N2
Conseiller patrimoine	Consultation des portefeuilles clients assignés	N2 – N3
Analyste risques	Analyse stratégique du portefeuille global	N3
Équipe conformité / AML	Alertes fraude, sanctions, blanchiment	N3 – N4
Audit interne	Investigations transverses, contrôle des habilitations	N2 – N4
Équipe juridique	Échanges réglementaires, validation juridique	N3 – N4
Cadres commerciaux	Pilotage commercial, accès aux KPIs agrégés	N2
Expert régional temp.	Investigation ponctuelle, accès borné dans le temps	Variable

Table 1 : Acteurs et niveaux d'accès

2.2 Opérations métier principales

Opération	Acteurs autorisés	Contrôle requis
Consultation données clients	RC, GP, BO, Guichetier	RBAC + filtre ABAC
Traitement opérations bancaires	BO, RC, Guichetier	Double validation > 50 k €
Opérations guichet (dépôts/retraits)	Guichetier	Vérification identité + N1
Consultation portefeuilles détaillés	GP, Risques	Filtre ABAC portefeuille
Analyse de risque stratégique	Analyste risques	Lecture seule

Opération	Acteurs autorisés	Contrôle requis
Gestion KYC avancée	Conformité	MFA + double validation
Traitement alertes fraude/sanctions	Conformité / AML	Isolation + MFA
Investigations internes	Audit, Juridique	Accès borné dans le temps
Échanges avec autorités	Juridique	Journalisation renforcée

Table 2 : Opérations et contrôles associés

3. Modèles de contrôle d'accès

3.1 RBAC — Role-Based Access Control

Principe. Les permissions sont attachées au rôle, et l'utilisateur hérite des droits de son rôle organisationnel.

Pourquoi ce modèle est nécessaire. La banque dispose de rôles métier bien définis (conseiller, analyste, guichetier, auditeur…). RBAC permet de les modéliser directement : quand un employé change de poste, on modifie son rôle, et toutes ses permissions se mettent à jour automatiquement. Il garantit aussi la séparation des fonctions : un guichetier n'hérite jamais des droits AML par construction du système.

Limites. RBAC seul est insuffisant : deux conseillers patrimoine ont le même rôle mais ne doivent pas voir les mêmes clients. Il faut un filtrage contextuel en complément.

3.2 ABAC — Attribute-Based Access Control

Principe. La décision d'accès est calculée en temps réel selon des attributs de l'utilisateur, de la ressource et du contexte.

Pourquoi ce modèle est nécessaire. ABAC répond aux limites de RBAC en ajoutant quatre filtres contextuels :

- **Portefeuille :** le conseiller ne consulte que les clients qui lui sont assignés
- **Pays :** les données d'un client sont accessibles uniquement depuis sa juridiction
- **Sensibilité :** un dossier passant de N2 à N4 pendant une enquête déclenche automatiquement des contrôles plus stricts
- **Temporalité :** les accès des experts régionaux sont bornés dans le temps et révoqués automatiquement à échéance

3.3 BLP — Bell-LaPadula (confidentialité)

Principe. Deux règles fondamentales s'appliquent à toutes les données classifiées :

- **No read up :** un utilisateur ne peut pas lire une donnée de niveau supérieur au sien
- **No write down :** un utilisateur ne peut pas copier ou écrire une donnée vers un niveau inférieur

Équipe	Peut lire	Peut écrire	Justification
Guichetier (N1)	N1 uniquement	N1 uniquement	Accès strictement limité au comptoir
Back-office (N2)	N1, N2	N1, N2	Pas d'accès aux dossiers stratégiques
Analyste risques (N3)	N1, N2, N3	N3 uniquement	No write down vers N2 ou N1
Conformité AML (N4)	N1 à N4	N4 uniquement	Isolation totale des dossiers critiques
Audit interne	N1 à N4	Aucun (lecture seule)	Indépendance et non-altération

Table 3 : Application de BLP par équipe

3.4 Biba — Modèle d'intégrité

Principe. Biba est le symétrique de BLP, appliqué à l'intégrité plutôt qu'à la confidentialité :

- **No read down :** un utilisateur de haut niveau ne lit pas des données de niveau inférieur (pour ne pas contaminer ses analyses)
- **No write up :** un utilisateur de bas niveau ne peut pas modifier des données de niveau supérieur

Application au guichetier. Sans Biba, un guichetier (N1) pourrait altérer les journaux d'audit (N4). Biba interdit ce scénario en protégeant l'intégrité des données critiques, indépendamment de la confidentialité.

3.5 Chinese Wall — Brewer-Nash (conflits d'intérêt)

Principe. Les barrières d'accès sont dynamiques et évoluent selon l'historique des consultations. Une fois qu'un utilisateur a accédé aux données d'une entité, il est automatiquement bloqué sur les données des entités conflictuelles.

4. Architecture en couches

Les cinq modèles s'appliquent en séquence. Un accès n'est accordé que si toutes les couches le valident simultanément.

Couche	Modèle	Question posée
1	RBAC	Le rôle de l'utilisateur est-il autorisé ?
2	ABAC	Le contexte (pays, portefeuille, durée) est-il valide ?
3	BLP	Le niveau de confidentialité est-il compatible ?
4	Biba	L'intégrité des données est-elle préservée ?
5	Chinese Wall	Absence de conflit d'intérêt ?

Table 4 : Séquence de validation des accès

À chaque étape, un échec entraîne un refus immédiat, une alerte sécurité et une entrée dans le journal d'audit.

5. Niveaux de sécurité

Niv.	Désignation	Données	Contrôles
N1	Interne métier	Opérations courantes, référentiels, comptoir guichet	Authentification standard
N2	Sensible	Données clients, contrats, historiques	Auth. + journalisation
N3	Très sensible	KYC détaillé, risque stratégique	MFA + justification métier
N4	Critique	AML, sanctions, investigations	MFA + double validation + isolation

Table 5 : Classification des données et contrôles associés

6. Division en équipes et effectifs

Périmètre : banque internationale, **550 employés** (avec 50 guichetiers supplémentaires), présence multi-pays, activités de détail, patrimoine et conformité réglementaire.

6.1 Guichetier — 50 agents (9%)

Rôle. Le guichetier est le premier point de contact physique du client en agence. Il effectue les opérations de caisse courantes : dépôts, retraits, remises de chèques, virements simples, délivrance de relevés d'identité bancaire et vérification d'identité des porteurs. Il oriente les clients vers les conseillers compétents pour les opérations complexes.

Justification de l'effectif. Dans la banque de détail, le ratio standard est de 1 guichetier pour 200 clients actifs en agence (référence Banque de France, rapport sur l'accessibilité bancaire 2023). Avec 10 000 clients actifs répartis sur plusieurs agences, 50 guichetiers constituent l'effectif minimum opérationnel pour garantir des temps d'attente acceptables aux heures de pointe.

Modèles appliqués. RBAC attribue le rôle *guichetier* avec accès N1 uniquement. L'accès aux données clients est strictement limité : le guichetier peut vérifier l'identité et le solde disponible, mais n'a aucun accès aux historiques détaillés, aux produits d'épargne ou aux informations patrimoniales. ABAC filtre par agence d'affectation : un guichetier de l'agence de Tunis-Centre ne peut pas consulter les clients d'une agence de Sfax ou de Paris, même avec le même rôle RBAC.

Restrictions clés. Accès interdit à tout élément N2 ou supérieur. BLP bloque tout accès vers le haut par construction. Biba interdit toute modification des dossiers clients permanents — le guichetier peut saisir une transaction mais ne peut pas altérer un historique ou un profil client. Double validation obligatoire au-delà de 5 000 euros en caisse. Aucun accès aux analyses de risque, aux dossiers KYC, ni aux investigations.

6.2 Relation clientèle — 120 agents (22%)

Rôle. Premier point de contact avec les clients particuliers et entreprises pour les opérations non-guichet. Les conseillers ouvrent les comptes, traitent les demandes courantes, collectent les informations KYC de base et orientent les clients vers les métiers spécialisés.

Modèles appliqués. RBAC attribue le rôle conseiller avec accès N1–N2 uniquement. ABAC filtre par portefeuille assigné : un conseiller de Tunis ne peut pas consulter les clients d'un collègue de Paris, même s'ils ont le même rôle. BLP bloque tout accès vers N3 ou N4 par construction.

6.3 Back-office — 80 agents (15%)

Rôle. Le back-office est le moteur opérationnel invisible de la banque. Il traite les virements, rapprochements comptables, ordres de marché et corrections d'anomalies administratives.

Modèles appliqués. RBAC limite les droits au périmètre opérationnel N1–N2. Biba est le modèle critique : la règle *no write up* interdit formellement à un agent BO de modifier un dossier de niveau N3 ou N4. Double validation obligatoire au-delà de 50 000 euros.

6.4 Gestion de patrimoine — 60 conseillers (11%)

Rôle. Les conseillers patrimoniaux gèrent des clients à haute valeur nette (HNWI). Accès aux données financières détaillées : compositions de portefeuille, ordres de marché, stratégies d'investissement.

Modèles appliqués. ABAC est le modèle central avec filtre absolu par portefeuille assigné. Chinese Wall s'applique également pour prévenir tout délit d'initié.

6.5 Risque — 40 analystes (7%)

Rôle. Surveillance des expositions de la banque : risque de crédit, de marché et opérationnel. Production des reportings prudentiels exigés par Bâle III/IV.

Modèles appliqués. BLP en lecture seule stricte. Chinese Wall sur les décisions d'investissement.

6.6 Conformité / AML — 35 agents (6%)

Rôle. Équipe la plus sensible du système. Traitement des alertes de blanchiment, surveillance des transactions suspectes, gestion KYC approfondie, application des sanctions internationales (OFAC, ONU, UE).

Modèles appliqués. Les cinq modèles s'appliquent simultanément. Les dossiers AML actifs sont physiquement inaccessibles aux cadres commerciaux — exigence non négociable inscrite dans la directive AMLD6.

6.7 Audit interne — 20 auditeurs (4%)

Rôle. Garant indépendant de l'efficacité du système de contrôle. Vérifie que les accès sont correctement attribués et que les journaux d'audit sont complets.

Modèles appliqués. BLP en mode lecture seule absolue (N1 à N4). Aucune modification possible, sans exception.

6.8 Juridique — 20 juristes (4%)

Rôle. Validation des opérations complexes, gestion des contentieux, échanges avec les autorités de régulation.

Modèles appliqués. BLP sur le périmètre de compétence. Chinese Wall critique pour éviter tout accès aux données de la contrepartie adverse.

6.9 Cadres commerciaux — 25 cadres (5%)

Rôle. Pilotage de la performance commerciale. Accès aux KPIs agrégés uniquement. BLP garantit qu'aucun directeur régional ne peut lire un dossier AML N4.

6.10 Experts régionaux temporaires — pool de 10

Rôle. Mobilisés ponctuellement pour des investigations nécessitant une connaissance locale approfondie. ABAC gère la temporalité, le périmètre et la révocation automatique.

6.11 Récapitulatif des effectifs

Équipe	Effectif	Part	Modèles prioritaires
Guichetier	50	9%	RBAC N1, ABAC (agence), Biba
Relation clientèle	120	22%	RBAC, ABAC (portefeuille, pays)
Back-office	80	15%	RBAC, Biba
Gestion patrimoine	60	11%	ABAC, Chinese Wall
Risque	40	7%	BLP (lecture), Chinese Wall
Conformité / AML	35	6%	BLP + Biba + CW, isolation N4

Équipe	Effectif	Part	Modèles prioritaires
Audit interne	20	4%	BLP (lecture seule absolue)
Juridique	20	4%	BLP, Chinese Wall
Cadres commerciaux	25	5%	RBAC N2, BLP bloque N4
Experts régionaux	≈10	2%	ABAC temporalité, Biba
Fonctions support	90	16%	RBAC, ABAC base
Total	550	100%	

Table 6 : Effectifs et modèles prioritaires par équipe